

RESEARCH WORKBOOK

Inter-Session Credential Exposure on Shared University Endpoints A Field Guide for Measurement, Intervention, and Publication

Khondokar Sajid | ID: 2211954042 | CSE, North South University Supervisor: Dr. Nova Ahmed, DIAL Lab Target: IEEE Access submission by end of August

This workbook is your working field guide. It tells you what to do, in what order, who to talk to, what to say to them, how to measure before and after the intervention, how to collect and record data, and what to do with that data when you have it. Work through it step by step. Tick the checkboxes as you go.

Step	What it covers	Days
Step 1	Get the permissions and authorizations	1–5
Step 2	Talk to the IT Office — what to say and what to ask	3–7
Step 3	Baseline measurement — before anything changes	6–14
Step 4	Survey and interview — the human side	10–18
Step 5	Deploy the intervention on Lab A	15–22
Step 6	Post-intervention measurement — after the change	23–35
Step 7	Data collection and recording — how to keep everything	Throughout
Step 8	Analyze and write the paper	36–50
Step 9	Submit and what comes next	50+

STEP 1 — GET THE PERMISSIONS FIRST

Before you touch any machine, send any survey, or deploy anything — you need four things in writing. This is not optional. The Cyber Security Ordinance 2025 applies. Without written authorization, anything you do on NSU machines is legally risky for you personally.

What you need in writing:

- Permission from NSU IT Director: run read-only audit script on lab machines
- Permission from NSU IT Director: deploy Chrome/Edge policies and Shared PC Mode on one lab (Lab A only)
- Ethics committee approval: survey students, conduct simulated extraction using test accounts only
- MoU with Dr. Nova Ahmed: your name as first author, her as co-author, nine-month timeline, open-source scripts

How to get them:

- Dr. Nova Ahmed gives you access to the IT Director. Ask her at the first meeting after Eid to introduce you or write a short email. Her name opens the door.
- For the IT Director: bring a one-page summary of the research (use the technical proposal already prepared). Do not ask for permission to 'hack' anything. Ask for permission to 'audit and improve the security configuration of one laboratory as part of a supervised research project.' These are different sentences.
- For ethics: ask Dr. Nova Ahmed what NSU's ethics review process is. Some universities have a formal IRB. Some require only a department-level approval. She will know. Submit the protocol before any data collection.
- For the MoU: draft it yourself, one page, and bring it to the first meeting. Include: title of research, names and roles, deliverables, timeline, authorship, open-source release clause.

Do not proceed to Step 2 until at least the IT permission and Dr. Ahmed's agreement are confirmed.

STEP 2 — TALKING TO THE IT OFFICE

The IT office can say no for any reason. Your job is to make it easy for them to say yes. They are not your audience for the research — they are your co-deployers. Do not walk in with a presentation. Walk in with a one-page list of exactly what you need them to do, how long it takes, and what risk they carry.

What to say when you sit down with the IT Director:

- 'I am working on a supervised research project under Dr. Nova Ahmed in DIAL Lab. We want to measure and fix a security gap on NSU lab computers that is currently exposing student credentials. The fixes are free — all built into Windows and Chrome. I need thirty days on one lab.'
- Show them the demo on your laptop: open Chrome, go to `chrome://settings/passwords`, show a saved password visible with just the Windows password. Say: 'This is what any student can do on any lab PC right now, in thirty seconds, with no tools.' Let the silence sit.
- Then show them Scenario 3 from your demo — the same machine after the fixes, nothing to extract. 'After four free settings, this is impossible.'

What you need IT to actually do — give them this list:

Task	What it involves	Their effort
Allow audit script to run	A read-only PowerShell script that checks current policy settings on lab machines. It reads config files, only shows the output, and does not change anything.	20 minutes to read, 5 minutes to run, 5 minutes to confirm.
Push Chrome/Edge policies	Download Chrome ADMX templates. Add six registry keys under <code>HKLM\SOFTWARE\Policies\Google\Chrome</code> . Add from GPO. You apply the policies.	10 minutes to download, 10 minutes to push, 10 minutes to apply.
Enable Windows Shared PC Mode	Change PC Mode setting on a MDM CSP. Enable <code>SharedPCMode = True</code> , <code>DeletionPolicy = 0</code> (delete profile on logout).	5 minutes to change, 5 minutes to confirm.
Enable Defender ASR	One PowerShell command per rule. Audit mode only — no blocking yet. You review the logs, they do nothing until you confirm.	5 minutes to run, 5 minutes to review.
Install Sysmon + Wazuh agent	Download Sysmon from Microsoft Sysinternals, install with your config XML. Install Wazuh agent if not already installed. Wazuh is a GPO.	10 minutes to download, 10 minutes to install, 10 minutes to confirm.
Allow Lab B to remain unchanged	Lab B changed control — no changes. Just confirm which lab it is.	Nothing — just leave it alone

Tell them: you will handle all the configuration files and scripts. You will give them exactly what to run. They just need to run it and allow it. If anything breaks, you will identify it and they can revert in five minutes via GPO.

STEP 3 — BASELINE MEASUREMENT (BEFORE ANYTHING CHANGES)

This is the most important step. You need to know what the situation is NOW, before any fix, so you can show the difference after. No baseline = no research. Do not skip or rush this.

3A — Policy State Audit

Run the following PowerShell one-liner on each lab machine (or ask IT to run it across the lab using a GPO startup script). Save the output for each machine.

```
gprresult /h C:\audit_output.html /f
reg query HKLM\SOFTWARE\Policies\Google\Chrome
reg query HKLM\SOFTWARE\Policies\Microsoft\Edge
Get-MpPreference | Select-Object AttackSurfaceReductionRules*
```

For each lab machine, record these values in your audit sheet:

Policy to check	Where to look	Current value (fill in)	Expected value
BrowserSignin	HKLM\...\Google\Chrome		0
SyncDisabled	HKLM\...\Google\Chrome		1
PasswordManagerEnabled	HKLM\...\Google\Chrome		0
ExtensionInstallBlocklist	HKLM\...\Google\Chrome		["*"]
DeveloperToolsAvailability	HKLM\...\Google\Chrome		2
BlockExternalExtensions	HKLM\...\Google\Chrome		1
Edge: BrowserSignin	HKLM\...\Microsoft\Edge		0
Edge: SyncDisabled	HKLM\...\Microsoft\Edge		1

Shared PC Mode enabled	SharedPC CSP / GPO		True
Shared PC DeletionPolicy	SharedPC CSP / GPO		0
ASR LSASS rule on	Get-MpPreference output		2 (Block)
Sysmon service running	services.msc / sc query		Running
Wazuh agent running	services.msc / sc query		Running

3B — Simulated Extraction Test (the most important measurement)

This is your primary outcome. On each machine you test, you are asking: can a standard-user attacker extract saved credentials left by the previous user? You measure this BEFORE the fix and AFTER the fix. The difference is your result.

Procedure — do this on Lab A machines and Lab B machines:

- Use only throwaway test accounts you own — never touch real student data.
- On Machine X: sign into Chrome with your test account (testuser1@gmail.com). Save 5 fake credentials (fake Facebook, fake bKash, fake NSU portal). Enable sync. Then sign out of Chrome (but do NOT sign out of Windows).
- Now as a 'new user' on the same Windows account: open Chrome. Check if the previous profile is still visible. Navigate to chrome://settings/passwords. Can you see the saved passwords? Enter the Windows lab password. Can you view and export them?
- Also run ChromePass.exe (download from NirSoft, carry on USB). Double click. Does it show the saved credentials from the previous session?

Record the result for each machine in this table:

Machine ID	Lab	Profile visible after logout	Passwords visible in settings?	ChromePass extracted?	Pass/Fail
PC-01	A				
PC-02	A				
PC-03	A				
PC-04	A				
PC-05	A				
PC-06	B				
PC-07	B				
PC-08	B				
PC-09	B				
PC-10	B				

Fail = attacker could extract credentials. Pass = nothing to extract. Your goal is: Lab A goes from mostly Fail to all Pass after the intervention. Lab B stays at mostly Fail (no changes made there — control group).

STEP 4 — SURVEY AND INTERVIEWS (THE HUMAN SIDE)

The technical measurement tells you if the fix works. The survey and interviews tell you why the problem exists, who is affected, and what people actually do and think. This is the HCI contribution — the part that makes this publishable in SOUPS and not just a technical report.

4A — Anonymous Survey

Distribute via Google Forms. Two versions: Bangla and English. No names. No student IDs. Anonymous completely. Target N = 300 responses.

Survey questions to include:

#	Question	Why you need it
Q1	How often do you use NSU lab computers? (Never / Sometimes / Often / Daily)	Establish baseline exposure level
Q2	Do you sign into Chrome with your personal Google account on lab computers? (Yes / No / Sometimes)	Measure compliance (Yes/No/Sometimes)

Q3	When you sign into Chrome on a lab PC, do you turn on sync? (Yes/No / sync is on by default, what sync is)	Measure sync awareness
Q4	When you finish using a lab computer, what do you do? (Just close browser / Sign out of Chrome / Sign out of Windows / Log out completely)	Measure sign out awareness
Q5	Have you ever sat down at a lab PC and found the previous user still signed in? (Yes/No)	Measure sign out awareness
Q6	If you found a previous user signed in, what did you do? (Signed in / Signed out / Told someone / Nothing)	Measure sign out awareness
Q7	Do you save passwords in Chrome on lab computers? (Yes / No)	Measure credential exposure behaviour
Q8	Do you know it is possible to export all saved Chrome passwords to a CSV file? (Yes / No)	Measure awareness of data export
Q9	Have you or anyone you know experienced an account being hacked after using a lab computer? (Yes / No / Prefer not to say)	Measure real world incident awareness
Q10	Gender (Optional): Female / Male / Prefer not to say	Needed to analyze if female students are disproportionately affected
Q11	Department: CSE / EEE / BBA / Other	Controls for technical background

Distribute the survey *BEFORE* the intervention (baseline) and *AGAIN* after (post-intervention). Compare the before and after results to see if awareness changed.

4B — Interviews (optional but powerful)

Ask for 8–10 student volunteers for a 15-minute conversation. Especially try to include female students — their experience is central to this research. Do not record without consent. Take written notes. Anonymize everything.

Key questions to ask in interviews:

- Tell me about how you normally use the lab computers.
- Have you ever worried about your privacy or security on a shared computer?
- Have you ever found a previous user still signed in? What happened?
- If something happened to your account — someone accessed it — would you report it? Why or why not?
- What stops people from talking about these things?

The answers to that last question — what stops people from talking — are the core of the HCI contribution. Especially from female students. This is what no existing Bangladeshi paper has collected.

STEP 5 — DEPLOY THE INTERVENTION ON LAB A

Only after baseline is complete. Only on Lab A. Lab B stays untouched. This is the actual change you make — the fix. Do each item in order.

Deployment checklist — do in this order:

- Week before deployment: Post signage in Lab A in Bangla and English. 'Starting [date], this lab will have new security settings. Nothing you save here will remain after you log out. Save all your work to Google Drive.'
- Day 1: Ask IT to push Chrome/Edge policies via GPO to Lab A OU only. Give them the registry file you have already prepared.
- Day 1: Ask IT to enable Windows Shared PC Mode on Lab A machines. DeletionPolicy = 0.
- Day 2: Verify policies are live. On one Lab A machine, open Chrome and try to sign in — it should refuse. Try to save a password — option should be greyed out.
- Day 3: Ask IT to enable Defender ASR rules in AUDIT MODE. Not Block yet.
- Day 3: Install Sysmon with your config XML on Lab A machines. Install Wazuh agent, point to your manager.
- Day 4–10: Monitor Wazuh. Check for any legitimate software triggering ASR rules. Build the extension allowlist based on what faculty and students actually need.
- Day 11: Move ASR rules from Audit to Block mode after confirming no false positives.
- Day 11: Push the extension allowlist via ExtensionInstallAllowlist policy.
- Day 12: Run the simulated extraction test again on Lab A as a quick sanity check. Should fail to extract. Record result.

If something breaks:

- Chrome policies: revert by deleting the registry keys under HKLM\SOFTWARE\Policies\Google\Chrome. GPO rollback takes effect at next login.
- Shared PC Mode: set EnableSharedPCMode = False. Reboot.
- ASR rules: run Set-MpPreference with Actions = AuditMode for the offending rule.
- Sysmon/Wazuh: stop and uninstall the services. No data loss, no side effects.

Every change is reversible within minutes. Remind the IT Director of this.

STEP 6 — POST-INTERVENTION MEASUREMENT (AFTER THE CHANGE)

Wait at least one week after deployment before running post-intervention measurement. This gives time for the changes to stabilize and for students to encounter the new settings. Then repeat exactly the same tests you did in Step 3.

6A — Run the extraction test again on Lab A and Lab B

Same procedure as Step 3B. Same test accounts. Same ChromePass tool. Record results in the same table format. Lab A should now show all Pass. Lab B should still show all Fail (no changes were made).

6B — Run the policy audit again on Lab A

Same PowerShell audit from Step 3A. Confirm all expected values are in place. This verifies the deployment is still active and has not been reverted.

6C — Redistribute the survey

Send the same Google Form to the same population. Compare before and after on questions Q2 (sign into Chrome), Q3 (sync), Q4 (session termination), Q5 (found previous user signed in), Q8 (aware of CSV export). Even a small awareness change is worth reporting.

6D — Check Wazuh logs

Pull the Wazuh event summary for Lab A over the intervention period. Look for: any triggered LSASS access alerts, any suspicious process creations, any registry Run key modifications, any outbound connections to Telegram or Discord from non-browser processes. Even if there are no real attacks, the presence of the monitoring capability is worth reporting. If there ARE real suspicious events — that is a significant finding.

STEP 7 — DATA COLLECTION AND RECORDING

Everything must be recorded at the time it happens, not from memory later. Keep one folder on Google Drive for the entire research. Never store actual student credentials anywhere — not even encrypted. Only store metadata (counts, pass/fail, policy values).

Files to keep in your research folder:

File name	What goes in it	Format
audit_baseline_labA.csv	Policy state of each Lab A machine before intervention	CSV — one row per machine
audit_baseline_labB.csv	Policy state of each Lab B machine — no changes expected	CSV — one row per machine
audit_post_labA.csv	Policy state of Lab A after intervention — verify deployment	CSV — same format
extraction_results.csv	Pass/fail extraction test results, before and after, Lab A and B	CSV — one row per test
survey_before.csv	Raw Google Forms export, baseline survey	CSV from Google Forms
survey_after.csv	Raw Google Forms export, post-intervention survey	CSV from Google Forms
interview_notes.txt	Anonymized interview notes — no names, no IDs	Plain text, one entry per participant
wazuh_events_labA.txt	Summary of Wazuh alerts during intervention period on Lab A	Text export from Wazuh dashboard
deployment_log.txt	Date and time of each deployment action, what was done, who	Anonymized diary
IRB_approval.pdf	Ethics committee approval document	Scanned PDF

IT_authorization.pdf	Written permission from IT Director	Scanned PDF
----------------------	-------------------------------------	-------------

What your primary comparison looks like:

Metric	Lab A Before	Lab A After	Lab B Before	Lab B After (control)
Extraction success rate (% of machines where credentials were extracted)	____ %	____ %	____ %	____ %
Machines with SyncDisabled = 1	____ / ____	____ / ____	____ / ____	____ / ____
Machines with Shared PC Mode on	____ / ____	____ / ____	____ / ____	____ / ____
Survey: % who sign into Chrome on lab PCs	____ %	____ %	N/A	N/A
Survey: % aware of CSV password export	____ %	____ %	N/A	N/A
Survey: % who found previous user signed in	____ %	____ %	N/A	N/A
Wazuh: suspicious events flagged	N/A	____	N/A	N/A

Fill these in as you collect data. This table becomes Table 1 in your paper.

STEP 8 — ANALYZE AND WRITE THE PAPER

Write sections as the data comes in — not all at the end. Introduction and Background can be written in Days 1–14. Methodology in Days 15–22. Results the moment you have data. Discussion and Conclusion last.

Paper structure and when to write each section:

Section	What to write	Write on days
Title + Abstract	Title: Sync by Default, Leak by Default: Measuring and Mitigating Inter-Session Credential Exposure on Shared University Endpoints	Days 49–50
1. Introduction	The real scenarios (UIU student, exam leak) — fully anonymized. The gap: no Bangladeshi research on this. RQ1–RQ4. Contributions	Days 1–14
2. Background	Verizon 2025 DBIR. Snowflake breach (Mandiant 2024). Lain et al. IEEE S&P 2022 (syncing does not work). NIST Phish Scale. CVEs	Days 1–14
3. Threat Model	Class A through F. The six attack scenarios. Who the attacker is. What they can do.	Days 6–14
4. Methodology	Lab A vs Lab B design. Phases. Simulated extraction procedure. Survey design. Interview design. Ethics commitments.	Days 15–22
5. Results	Extraction success rate table. Policy audit findings. Survey before vs after. Interview before vs after. Wazuh events.	Days 23–45
6. Discussion	What worked. What broke. Unintended consequences. Cost and trade-offs. Implications for Bangladeshi universities.	Days 46–48
7. Conclusion	Summary. Call to action for other institutions. Open-source release of scripts. Future work	Day 49
References	IEEE numbered format. All citations verified.	Throughout

Statistical analysis — keep it simple and honest:

- Primary: compare extraction success rate Lab A before vs after using McNemar's test (paired binary outcome — same machines, two time points). Report exact p-value.
- Secondary: compare Lab A after vs Lab B after using Fisher's exact test (two independent groups, binary outcome).
- Survey: report percentages and use chi-square for before vs after comparisons on categorical questions.
- Interviews: thematic analysis — identify 3–5 recurring themes from the notes, describe each with anonymized quotes.

You do not need advanced statistics. Simple, honest, correctly applied tests are far better than complex ones done wrong.

STEP 9 — SUBMIT AND WHAT COMES NEXT

Submission checklist for IEEE Access:

- Paper is 8–12 pages, double column, IEEE format (download template from ieeaccess.ieee.org)
- All references are in IEEE numbered format and verified
- All figures and tables have captions
- Ethics statement included in the paper (IRB approval, no real credentials collected)
- Author contributions statement included
- Open access fee waiver application submitted (IEEE has waivers for authors from developing countries)

- Cover letter written: one paragraph explaining the contribution and why it fits IEEE Access
- Dr. Nova Ahmed has reviewed and approved the final draft
- Submit at ieeaccess.ieee.org — create account, follow submission wizard

After submission — what to do while you wait:

- Do not sit idle. Start preparing the SOUPS 2026 submission — different format, stronger HCI framing, more focus on the interview findings and the female-student angle.
- Push all deployment scripts, GPO XML files, Wazuh rules, and the audit script to your personal GitHub under MIT license. Name the repo clearly. Credit NSU and DIAL Lab.
- Ask Dr. Nova Ahmed for a reference letter for your Australian Master's applications. The right time to ask is when the paper is submitted — not before.
- If reviewers come back with revisions — treat them as gifts. Respond to every comment, even the ones you disagree with. Explain your reasoning politely. Revise and resubmit within the deadline.

The UIU student paid twenty lakh taka and lost everything anyway — because of a default browser setting nobody had changed. You know how to change it. You have the supervisor, the lab, and the plan. Every step in this workbook is a step toward making sure the next student does not become that story. Work through it one step at a time.

Khondokar Sajid | ID: 2211954042 | CSE, NSU | DIAL Lab